

Varakumar G

varakumar7000@gmail.com | +916309856263 | linkedin.com/in/varakumar01
GitHub | GitLab | Portfolio | Letter of Recommendation

PROFESSIONAL SUMMARY

Security Engineer with 2+ years in **application and API security** — manual exploitation, **secure code review**, and **SAST/DAST** across web apps and APIs. Assessed and exploited a live billing application end-to-end (**IDOR**, **privilege escalation**, **SQL injection**, **XSS**, weak **JWT** handling) and reported it via a **GitHub Security Advisory**. Tests **API security** against **crAPI/VAmPI** with **Burp Suite** and **Postman**, scoring findings with **CVSS** and working to **OWASP Top 10**, **PCI-DSS**, and **ISO 27001**.

Automated plugin development for OT security to keep pace with the volume, and I contribute to **open-source** security testing projects because I want the tools I depend on to stay secure.

TECHNICAL SKILLS

Security Domains: Application Security, API Security, Secure Code Review, SAST/DAST, Vulnerability Management, Cloud Security

AppSec & API Testing: Burp Suite, Postman, crAPI, VAmPI, Metasploit, Nmap, Wireshark, Hashcat

Vulnerability & Cloud Scanning: Nessus, OpenVAS, Qualys, CloudSploit, NVD, CVSS, AWS, Microsoft Azure, GCP, Oracle Cloud

Network & Security Protocols: IPsec, Kerberos, LDAP, TLS/SSL, DNS, DHCP, SNMP, SMB, RDP, SSH, HTTP/HTTPS

Frameworks & Standards: OWASP Top 10, MITRE ATT&CK, NIST CSF, CIS Benchmarks, CVSS, PCI-DSS, ISO 27001

Programming & Platforms: C, Python, Node.js, Bash, MongoDB, MySQL, Kali Linux, Arch Linux, WireGuard

PROFESSIONAL EXPERIENCE

Holm Security AB | Security Engineer

Randstad.in

- Grew **OT/SCADA CVE coverage from 400 to 3,200+** within a year — a **700% increase** — across products from **Siemens, Schneider Electric, Rockwell Automation, ABB, Emerson, and Honeywell**.
- Managed the **CloudSploit platform end-to-end** across **AWS, Azure, GCP**, and **Oracle** against **CIS Benchmark** controls, reviewing and contributing security fixes upstream to the open-source codebase.
- Automated development and validation of vulnerability and **API security** checks using **Claude AI**, reviewing every generated check before it shipped.
- Reported findings to clients with **CVSS**-scored severity, remediation guidance, and re-validation after fixes.

Independent Security Assessment

- Bill Manager (E-commerce/Billing App) — Independent Web Application Assessment:**
 - Assessed and exploited a live billing application end-to-end: **broken access control** between user and admin roles, **insecure direct object reference (IDOR)** on invoices/billing records, **privilege escalation** via role/parameter tampering, **SQL injection** on login and search fields, **stored/reflected XSS**, an insecure password-reset flow, and weak **session/JWT** handling.
 - Reported every finding with remediation guidance through a **GitHub Security Advisory** on the project repository.
- Web & API Security Testing (PortSwigger Web Security Academy):**
 - Exploited **SQL injection**, **XSS**, **CSRF**, **authentication bypass**, **access control**, **SSRF**, **XXE**, and **insecure deserialization** labs hands-on, carrying the same techniques into **API security testing** on **crAPI/VAmPI**.
- Active Directory Security Assessment:**
 - Executed core AD attack paths end-to-end: **Kerberoasting**, **LLMNR/NBT-NS poisoning**, **pass-the-hash**, and **privilege escalation** via misconfigured **ACLs**.
 - Building toward advanced AD attack-path expertise: **ADCS abuse (ESC1 to ESC8)**, **delegation attacks** (unconstrained, constrained, resource-based), **Shadow Credentials**, and **BloodHound**-driven attack path analysis.

PROJECTS

- Subdomain & Attack Surface Enumeration Tool** | Python, Requests, dnspython
Turns a target scope into a prioritized attack surface: enumerates subdomains from public sources like **crt.sh**, **brute-forces** the remainder over **DNS**, then scans open ports and fingerprints each host's stack with **OpenVAS** plus custom backend-fingerprinting plugins.
- Self-Maintained OpenVAS Scanner** | Nmap, NASL
Maintain a fork of **OpenVAS** carrying custom **NASL** plugins for **CVE** checks the default feed doesn't cover, plus fingerprinting logic for newer software. AI-automated scripts keep the feed current as CVEs are published, so findings map to exploitable conditions, not stale signatures.
- Local Lab Setup**
 - Active Directory lab:** Built a **domain controller** and client machines to run full attack chains hands-on — **Kerberoasting**, **LLMNR poisoning**, **privilege escalation**.
 - pfSense + Vulnerable VMs:** Home lab behind a **pfSense** firewall with intentionally vulnerable targets (**Metasploitable**, **DVWA**, **VulnHub**) covering the full recon-to-exploit flow.

CERTIFICATIONS

- Offensive Security Certified Professional (OSCP) | OffSec | *In Progress*
- TCM Security: Practical Ethical Hacking • Windows & Linux Privilege Escalation • OSINT Fundamentals • External Pentest Playbook

EDUCATION

Malla Reddy College of Engineering & Technology, Hyderabad, India
Bachelor of Technology (B.Tech), Computer Science

2018 – 2022